第九届“强网”拟态防御国际精英挑战赛

设计安全大赛赛题

面向软件多样性的异构变体构造与安全增益验证

一、题目背景

随着软件系统的规模与复杂度持续增长，依赖单一实现、单一编译链或单一运行环境的防御方式，容易因共享缺陷与攻击路径复用产生共因失效。N-Version Programming（N 版本程序设计）与软件多样性技术通过构造功能等价、内部实现或运行形态不同的软件变体，降低同一攻击、利用原语或攻击链在多个变体上同时成功的可能性。

本赛题采用开放式作品赛形式。参赛队伍自主选择基准程序，设计并实现可自动化运行的异构变体生成流水线，利用流水线生成两个功能等价的软件变体，并自主完成不少于 3 个漏洞的复现、监测、对比与结果分析。赛题重点考查变体构造方法的创新性、泛化能力与实用性，以及参赛队伍对软件多样性安全增益的可复现验证能力。

二、题目描述

参赛队伍应提交一套完整的“基准程序输入—异构变体自动生成—漏洞验证与差异检测—安全增益分析”作品。评审将综合考察系统自动化程度、变体差异的有效性、漏洞与攻击类型的丰富度、攻击跨变体迁移难度、证据完整性与工程可用性。

1. 基准程序选择

参赛队伍可自主选择自主开发或合法获得的开源软件作为基准程序。基准程序应具有明确的功能接口、可复现的构建与运行方式，并能在 Linux x86-64 环境中部署。鼓励具有网络接口或外部输入处理能力的真实软件或有代表性的组件。基准程序的来源、版本、许可证、依赖与已知限制须在文档中说明。

过于简单、仅为展示某一个漏洞而临时编写的单功能样例，可用于方法说明，但其实用性和泛化能力评分将受到限制。

2. 异构变体生成流水线

参赛队伍应自主设计并构造自动化流水线系统。系统接收基准程序、构建参数和变换策略作为输入，自动完成分析、变换、构建、打包、部署与日志记录，输出可独立运行的异构变体。流水线可采用下列方法，鼓励组合多类方法或提出新的方法：

1）对于无源码基准程序，可采用二进制改写或程序加载多样化，如指令替换、寄存器重分配、基本块布局变换、地址空间与库加载多样化等；

2）对于有源码基准程序，可采用多样化编译方法，如配置不同编译器、优化级别、链接策略、防护机制或可控随机化参数的组合；

3）代码生成多样化，如跨语言代码转换与翻译、中间表示变换、语言迁移、等价代码重构或自动生成；

4）攻击链多样化，如通过运行环境、组件拆分、权限分离、调用路径、运行时选择或隔离策略的差异，使攻击者难以在不同变体上复用同一完整攻击链。

流水线应具有可重复执行的命令、配置文件或图形化操作界面，并记录工具版本、变换参数、随机种子、构建日志和产物标识。仅修改时间戳、签名、调试信息、压缩形式或其他不影响安全行为的表面差异，不计为有效异构。

异构生成策略约束：

1） 针对某个已知漏洞人工修改源码或硬编码拦截特定测试输入，不得作为流水线多样化能力的主要证据。

2） 修复基准程序中的已知漏洞可作为异构生成策略，但由于是针对基准程序的定制化改造，其在实用性和泛化能力评分上将受到限制。

3. 异构变体

参赛队伍须使用所提交的流水线，基于同一基准程序生成并提交 2 个可独立部署和运行的变体，分别记为 V2 和 V3，基准程序记为 V1，共计 3 个软件变体。V2、V3 应保持与基准程序 V1 的外部功能、输入输出语义的一致性，并通过功能一致性测试。参赛队伍应对变体间的差异来源、变换层次、性能和资源开销进行量化说明。

4. 漏洞验证与差异检测

参赛队伍须自主选择、复现并验证不少于 3 个漏洞。漏洞可为基准程序的历史已知漏洞、可确认的软件缺陷，或在合法与受控条件下构造的漏洞。每个漏洞应具有明确的根因证据，包括

CVE/CWE 标识（如有）、影响位置、触发条件、攻击目标与安全影响。同一根因的多个测试输入只计为 1 个漏洞。

对每个漏洞，应使用相同触发输入或攻击意图等价的自动化脚本，分别在 V1、V2、V3 三个变体上运行，并形成对比结果。要求至少观察到 V1、V2、V3 对该漏洞的表现不一致，包括但不限于：

1）1 个变体触发漏洞而另 2 个未触发；

2）2 个变体触发漏洞而另 1 个未触发；

3）3 个变体均触发同一漏洞，但漏洞表现不一致（如攻击利用的原语、控制流结果、信息泄露程度或最终攻击目标不同），该不同可通过外部观察发现；

4）1 个变体能检测、隔离或拦截攻击，而另其他不能。

差异可通过主办方可复核的监测探针或程序返回结果比对证明。可使用程序退出状态、协议响应、日志事件、调试器或动态插桩事件、系统调用、进程状态、受控标记值等作为判定依据。仅有文件哈希、代码大小、地址或指令排列不同，而没有安全相关行为差异的，不计为漏洞表现不一致。

5. 攻击抑制与跨变体迁移效果分析

参赛队伍应对 V1、V2 和 V3 执行多组攻击或漏洞触发测试，以矩阵、表格或可视化方式展示不同变体的反应。应至少区分“漏洞未触发”、“漏洞触发但表现不一致”等维度结果。

鼓励覆盖内存安全、输入注入、身份认证与授权、信息泄露、业务逻辑、拒绝服务等多种不同类型。在满足不少于 3 个有效漏洞的基础上，漏洞数量越多、类型越丰富、证据越充分，评分越高。对具有随机性的变体或攻击，应进行多次重复试验，报告试验次数、随机种子、成功率与异常样本。

特别地，鼓励参赛队伍采用多阶段攻击链，证明软件变体通过阻塞多阶段中的某一特定阶段而非全部阶段达成攻击抑制效果。这将获得额外的得分。

6. 泛化能力与实用性

流水线应尽可能将变换逻辑与具体基准程序解耦，能通过配置、插件或标准化接口处理同类程序、不同版本或其他样例程序。鼓励参赛队伍使用额外程序或基准程序的其他版本进行迁移验证。作品应考虑安装部署、构建时间、运行开销、可观测性、失败处理与环境兼容性，不得仅在参赛队伍的特定机器上运行，如以容器镜像形式交付可在泛化能力与实用性方面获得更高的评分。

7. 测试安全要求

所有漏洞复现和攻击验证必须在参赛队伍有权控制的本地、虚拟机或容器隔离环境中完成，不得对未经授权的系统、账号、网络或数据实施测试。演示性攻击应使用无害化载荷和可回收数据，避免自传播、持久化、数据破坏或向外部网络发送敏感信息。

三、交付说明

1. 参赛作品应为参赛队伍独立设计、开发完成的原创性作品。对所使用的开源软件、第三方工具、数据集和外部代码应如实说明来源和许可证。严禁抄袭、剽窃、隐瞒外部成果或伪造实验数据。

2. 参赛队伍应在规定时间内完成系统设计、开发、漏洞验证、作品文档与演示材料。参赛包应能在评审环境中按文档重新构建和复现。

3. 作品文件建议以“战队名称+作品名称”命名。主要交付内容如下：

1. 作品简介

作品名称、参赛队伍与成员信息、选题动机、总体方案、主要创新点。

2. 设计文档

基准程序选择说明、威胁模型、流水线架构、变换原理、两个变体的生成过程与差异、泛化设计、安全边界、性能开销和已知限制。

3. 软件作品

异构变体生成流水线的完整源码、构建与安装脚本、配置文件、依赖清单、容器或虚拟环境文件、V1、V2 和 V3 变体及其可执行产物。若某部分因许可证限制无法提交，应提供合法获取和可复现构建方法。

4. 漏洞验证测试包

不少于 3 个漏洞的触发输入、无害化攻击脚本、监测探针或结果判定程序、自动化执行脚本、预期结果、必要的环境快照与重置方法。每项测试应能对 V1、V2 和 V3 生成统一格式的结果记录。

5. 测试报告

详细记录漏洞根因、攻击模型、测试环境、执行步骤、观测指标、原始数据、差异判定依据、漏洞—变体反应矩阵、攻击抑制效果、性能开销与结论边界。报告应区分“漏洞仍存在但利用受抑制”与“漏洞已消除”两类结论，不得以有限测试直接宣称绝对安全。

6. 运行与演示材料

安装部署手册、一键构建或执行说明、功能测试、故障排查指南、演示文稿和演示视频。演示应完整覆盖“生成两个变体—运行功能测试—执行漏洞测试—展示差异结果”的闭环过程。

7. 其他文档

除上述规定内容以外的其他作品相关材料，如实验数据集、第三方组件声明、测试环境配置、系统架构图与安全分析附录等。

四、评分规则

本赛题满分 100 分。其中核心技术评分 80 分，按“异构变体生成流水线 50 分+漏洞验证 30 分”平衡设置；作品质量和现场答辩各 10 分。

1. 异构变体生成流水线（50 分）

评分项	评分说明	分值
系统完整性与自动化	具备从 V1、V2 和 V3 构建、打包和日志记录的完整闭环；接口清晰，参数和随机种子可追溯，可重复执行。	12
创新性	变换层次、技术原理和方法组合合理；两个变体存在与安全行为有关的有效差异，而非仅为表面差异； 在变体构造策略、自动化编排、多方法融合、可观测性或安全机制方面具有创新点，且有实验证据支持。	20
泛化能力	变换逻辑与具体漏洞或单一程序解耦；能通过配置或标准接口处理其他版本或同类程序。提供额外迁移实例可获得高分。	10
实用性与开销	系统易于安装、部署和维护；对构建时间、运行性能、资源占用和兼容性影响有准确测试与取舍分析。	8

2. 漏洞验证（30 分）

评分项	评分说明	分值
基准程序与漏洞有效性	基准程序具有代表性和可复现性；漏洞根因、触发条件、影响范围和攻击目标证据充分。	3
基础漏洞验证	对前 3 个有效漏洞逐个评分，每个 2 分。须在 V1、V2 和 V3 上观察到可复核的安全相关表现差异，并提供自动化测试和判定证据。	6
额外漏洞数量	在前 3 个有效漏洞基础上，每增加 1 个符合要求的独立漏洞得 2 分，最高 6 分。同一根因的不同输入不重复计分。	6
漏洞与攻击类型丰富度	综合考察 CWE 类别、触发面、利用原语与攻击链层次的多样性。覆盖三类及以上明显不同的漏洞或攻击机制时可获得高分。	6
攻击抑制与跨变体迁移效果	将 V1、V2 和 V3 进行对比，评价相同攻击的迁移难度、利用成功率、攻击链中断情况和变体联合失效风险，最高 3 分； 如有多阶段攻击链测试例，最高 4 分。	7
实验严谨性与可复现性	测试包、探针、判定规则、原始数据和结果矩阵完整；随机性试验有多轮重复与成功率统计；结论边界清晰且可复核。	2

3. 作品质量与现场答辩（20 分）

评分项	评分说明	分值
作品质量	文档资料齐全、结构清晰；源码、基准程序、两个变体、测试脚本和配置完整可用；安装部署和复现说明准确；代码质量与工程规范良好。	10
现场答辩	讲解逻辑清晰，能准确说明方法原理、创新点和适用边界；能现场演示变体生成与漏洞验证过程；对评委质询回答准确、有证据支持。	10